

Phishing Incident Investigation Report

Project: Simulated SOC phishing investigation case study

Analyst: Riza Khan

Classification: Portfolio / Training Lab

Important note: This report uses safe simulated indicators. Suspicious domains use reserved .example domains.

1. Executive Summary

A suspicious email claiming to originate from PayPal was reported by a finance employee. The email attempted to pressure the user into verifying their account through a suspicious link. The investigation identified multiple phishing indicators including brand impersonation, a typosquatted sender domain, urgency-based social engineering, a suspicious verification URL, and credential harvesting intent.

The incident was assessed as a credential phishing attempt. No successful compromise is assumed in this simulated case study; however, the email presents a high risk because it could lead to credential theft if a recipient clicks the link and enters login details.

2. Incident Scenario

A finance employee received an email with the subject line 'Urgent: Your PayPal Account Has Been Limited'. The email claimed the user's account had been restricted due to unusual activity and instructed the recipient to verify the account within 24 hours.

Field	Value
Reported By	Finance employee
Reported To	SOC / Security Team
Initial Severity	High
Threat Type	Credential phishing
Primary Target	User credentials

3. Email Evidence

Header Field	Observed Value	Analyst Comment
From	PayPal Security Team <security-update@paypa1-support.example>	Suspicious domain uses paypa1 instead of paypal.
Reply-To	verification-team@paypa1-support.example	Reply-to does not use a legitimate PayPal domain.
Subject	Urgent: Your PayPal Account Has Been Limited	Creates urgency and fear.
URL	hxxp://paypal-security-verification-login.example/login	Lookalike verification domain, likely credential harvesting.
Greeting	Dear Customer	Generic greeting rather than personalised account information.

4. Phishing Indicators

Indicator	Evidence	Why It Is Suspicious
Brand impersonation	PayPal branding is implied	Attackers often impersonate trusted brands to increase user trust.
Typosquatting	paypa1-support.example	The number 1 is used to visually imitate the letter l.
Urgency	Verify within 24 hours	Pressure tactics reduce the chance of careful review.
Generic greeting	Dear Customer	Legitimate account notices often include customer-specific details.
Suspicious URL	paypal-security-verification-login.example	The domain is not a legitimate PayPal domain.

5. Indicators of Compromise

IOC_Type	Indicator	Confidence	Risk	Notes
Sender Email	security-update@paypa1-support.example	High	High	Impersonates PayPal support
Reply-To Email	verification-team@paypa1-support.example	High	High	Reply-to uses suspicious domain
Sender Domain	paypa1-support.example	High	High	Typosquatting: number 1 used instead of letter l
URL	hxxp://paypal-security-verification-login.example/login	High	Critical	Likely credential harvesting page
IP Address	203.0.113.45	Medium	Medium	Documentation/test IP range used in simulations
Subject	Urgent: Your PayPal Account Has Been Limited	High	Medium	Urgency-based social engineering

6. MITRE ATT&CK; Mapping

Technique_ID	Technique	Tactic	Evidence	Relevance
T1566	Phishing	Initial Access	Suspicious email sent to employee	Email is the delivery method
T1204	User Execution	Execution	User is asked to click verification link	Attack relies on user interaction
T1583.001	Acquire Infrastructure: Domains	Resource Development	Lookalike domain used	Attacker-controlled infrastructure is important
T1656	Impersonation	Defense Evasion	Email impersonates PayPal Security Team	Brand impersonation increases credibility

7. Incident Timeline

Time	Event	Analyst Notes
10:24	Suspicious email received	Email claims PayPal account limitation
10:31	User reports email to SOC	No link click confirmed in this scenario
10:37	SOC triage begins	Header, sender, subject, and URL reviewed
10:45	IOCs extracted	Domain, URL, sender, reply-to collected
10:52	MITRE mapping completed	Mapped to phishing and user execution
11:05	Containment recommendations issued	Block domain and search mail logs

8. Risk Assessment

Risk Category	Rating	Reasoning
Likelihood	High	The lure is realistic and uses a common brand impersonation technique.
Impact	High	Successful credential theft could lead to account takeover and business email compromise.
User Interaction Required	Yes	The attacker needs the user to click the link and submit credentials.
Overall Severity	High	The email has multiple strong phishing indicators and targets credentials.

9. Recommended Response Actions

Containment: Block the suspicious sender domain and URL. Search email logs for messages with similar subjects, senders, URLs, or lookalike domains. Quarantine matching emails if discovered.

Eradication: If a user clicked the link or submitted credentials, reset the user's password, revoke active sessions, review login activity, and check for suspicious mailbox rules.

Recovery: Confirm MFA is enabled, notify affected users, and monitor for suspicious login attempts or account changes.

Prevention: Add email filtering rules, domain monitoring for typosquatting, phishing awareness training, and simulated phishing exercises.

10. Detection Opportunities

Detection Area	Example Logic
Email gateway	Alert on external senders using brand keywords and suspicious domains.
Proxy/DNS	Block newly observed lookalike domains and suspicious verification URLs.
SIEM	Correlate inbound phishing email with user click, authentication, and mailbox events.
Identity platform	Alert on impossible travel, unusual sign-in location, or MFA fatigue after phishing delivery.

11. Lessons Learned

This lab demonstrates how a SOC analyst can move from a reported suspicious email to a structured investigation. The process includes reviewing email metadata, identifying social engineering indicators, extracting IOCs, mapping to MITRE ATT&CK, assessing risk, and producing clear response recommendations.

12. Conclusion

The suspicious email was assessed as a credential phishing attempt. The strongest evidence was the typosquatted sender domain, suspicious verification URL, urgency-based wording, and brand impersonation. Recommended actions include blocking the indicators, searching for related emails, verifying user impact, enforcing MFA, and improving phishing detection controls.

Appendix A - Simulated Email Sample

From: security-update@paypa1-support.example
Subject: Urgent: Your PayPal Account Has Been Limited
URL: hxxp://paypal-security-verification-login.example/login